

Flujo de Trabajo: De la Red al Servidor Web

Usando herramientas de que existen generalmente en Linux se puede se recomienda Kali Linux ya que las tiene preinstaladas.

Las herramientas a utilizar son:

- ping
- nslookup
- traceroute
- netdiscover
- waf00f
- sslscan

Para que tu auditoría sea ordenada, el resultado o *output* de una herramienta debe ser la entrada o *input* de la siguiente.

1. **Fase 1: Reconocimiento Pasivo y Resolución DNS:** nslookup.
Tu punto de partida. Si tu objetivo es un dominio (ej. `objetivo.com`), no puedes enviarle paquetes IP directamente. Usas **nslookup** para resolver el nombre de dominio a su dirección IP pública y descubrir registros clave (como servidores de correo o subdominios).

Ejemplo: `nslookup objetivo.com` te dará la IP `192.168.1.50`.

2. **Fase 2: Mapeo de Red e Identificación de Hosts:** netdiscover, ping, traceroute. Una vez que tienes rangos de red o IPs, necesitas saber qué equipos están encendidos y por dónde viajan tus datos.
 - **En red local:** Usas **netdiscover** para lanzar peticiones ARP y descubrir dispositivos activos en la subred sin depender de si tienen el cortafuegos activado para ignorar pings.
 - **En entornos externos:** Usas **ping** para una comprobación rápida de supervivencia (si responde) y **traceroute** para mapear la ruta y ver cuántos saltos (routers/firewalls) hay entre tú y el objetivo.

3. **Fase 3: Identificación de Protecciones Perimetrales:** wafw00f.
Antes de lanzar cualquier escaneo de vulnerabilidades agresivo a la web del objetivo, debes saber si hay un "guardián" bloqueándote. Usas **wafw00f** pasándole la IP o dominio descubierto en el Paso 1.

Si detecta un WAF (Web Application Firewall) como Cloudflare o ModSecurity, sabrás que debes moderar la velocidad de tus herramientas para que no bloqueen tu dirección IP.

4. **Fase 4: Análisis de Cifrado y Capa de Transporte:** sslyze / sslscan. Si el objetivo tiene un servidor web expuesto (puertos 443 HTTPS), pasas a evaluar la seguridad de su canal de comunicación usando **sslscan**.

Esta herramienta negociará diferentes algoritmos con el servidor para decirte si soporta protocolos obsoletos e inseguros (como SSLv3, TLS 1.0 o TLS 1.1) o si tiene certificados digitales mal configurados.

Tabla de Sincronía de Datos

Para que visualices cómo se conectan los datos entre sí durante tu auditoría, aquí tienes la matriz de entrada y salida:

Herramienta	¿Qué le ingresas? (Input)	¿Qué obtienes? (Output)	¿A qué herramienta se lo pasas?
nslookup	Nombre de dominio (ejemplo.com)	Dirección IP (192.168.1.50)	A ping, traceroute, o wafw00f
netdiscover	Rango de red local (192.168.1.0/24)	Lista de IPs y MACs activas	Eliges una IP objetivo para analizar

ping / tracert	IP del objetivo	Estado de conexión y ruta de red	Te da el contexto de saltos y conectividad
wafw00f	URL del servidor web	Presencia y tipo de Firewall Web (WAF)	Define si debes usar técnicas de evasión
ssllscan	URL/IP HTTPS del objetivo	Cifrados débiles y fallos en certificados	Reporte final de vulnerabilidades de capa SSL

Organizar tu flujo de esta manera te permitirá pasar de la incertidumbre a un proceso estructurado y repetible.

EJEMPLOS PRÁCTICOS

Guía de Comandos y Parámetros en Kali Linux

Para esta practica se pueden auditar a ustedes mismos desde Kali pueden auditar su propio router/modem o paginas publicas (tranquilos no iran presos por esto)

Fase 1: Resolución y Reconocimiento DNS

nslookup

Sirve para interrogar a los servidores DNS y obtener información de registros de un dominio.

- **Comando básico:**

```
nslookup uba.ar
```

- **Parámetros útiles:**
- `-type=mx`: Busca los servidores de correo del objetivo (muy útil para phishing o mapeo de infraestructura).
- `-type=txt`: Busca registros de texto (a menudo contienen políticas SPF de correo o verificaciones de servicios externos).
- **Ejemplo de uso avanzado:**

```
nslookup -type=mx uba.ar
```

Fase 2: Descubrimiento de Hosts y Mapeo de Red

`netdiscover`

Excelente para redes locales (como el laboratorio). Envía peticiones ARP de forma activa o pasiva para ver qué dispositivos están conectados, saltándose las restricciones de cortafuegos individuales que bloquean el ping tradicional.

- **Comando básico (Requiere privilegios de root/sudo):**

```
sudo netdiscover -r 192.168.1.0/24
```

- **Parámetros útiles:**
- `-r [rango]`: Define el rango de red a escanear (notación CIDR, ej. `192.168.1.0/24`).
- `-i [interfaz]`: Especifica la tarjeta de red a usar (ej. `-i eth0` o `-i wlan0`).
- `-p`: Modo pasivo. No envía paquetes, solo "escucha" el tráfico de la red para detectar hosts sin hacer ruido.

- **Ejemplo recomendado en VM:**

```
sudo netdiscover -i eth0 -r 192.168.1.0/24
```

ping

Verifica si el sistema operativo de destino está activo y respondiendo a nivel de capa de red (ICMP).

- **Comando básico:**

```
ping 8.8.8.8 #servidor de Google o 1.1.1.1 servidor de Cl
```

- **Parámetros útiles:**

- `-c [número]`: En Linux, el ping es infinito por defecto. Con `-c` limitas cuántos paquetes enviar (ej. `-c 4`).
- `-i [segundos]`: Define el intervalo entre paquetes (ej. `-i 0.2` para enviarlos más rápido).

- **Ejemplo recomendado:**

```
ping -c 4 192.168.1.150
```

traceroute

Te muestra la ruta exacta (los routers o saltos intermedios) que recorren tus paquetes para llegar al objetivo.

- **Comando básico:**

```
traceroute 192.168.1.150
```

- **Parámetros útiles:**

- `-I`: Usa peticiones ICMP Echo (ping) en lugar de paquetes UDP

para realizar la traza (a menudo los firewalls bloquean UDP pero permiten ICMP).

- `-T`: Usa paquetes TCP (por defecto en el puerto 80). Es ideal para atravesar cortafuegos que bloquean tanto UDP como ICMP.
- **Ejemplo recomendado:**

```
traceroute -T 192.168.1.150
```

Fase 3: Identificación de Cortafuegos Web (WAF)

wafw00f

Envía peticiones HTTP diseñadas para activar las respuestas típicas de los firewalls de aplicaciones web. Te dirá si hay algo filtrando tu tráfico web antes de que intentes escanear vulnerabilidades.

- **Comando básico:**

```
wafw00f http://192.168.1.150
```

- **Parámetros útiles:**
- `-a`: Escanea buscando todos los WAF posibles en lugar de detenerse en el primero que coincida.
- `-v`: Modo detallado (*verbose*). Te muestra qué respuestas HTTP específicas y cabeceras está analizando la herramienta.
- **Ejemplo recomendado:**

```
wafw00f -a uba.ar
```

Fase 4: Auditoría del Canal de Cifrado (SSL/TLS)

sslscan

Evalúa la configuración SSL/TLS del puerto web seguro (443). Te indicará si el servidor acepta cifrados antiguos que un atacante podría romper para interceptar el tráfico (ataques Man-in-the-Middle).

- **Comando básico:**

```
sslscan 192.168.1.150:443
```

- **Parámetros útiles:**

- `--no-failed`: Oculta de la pantalla los cifrados que el servidor rechazó. Esto limpia muchísimo la terminal y te deja ver únicamente lo que **sí está permitido** (lo que debes auditar).
- `--tlsoall`: Fuerza a evaluar exhaustivamente todas las versiones de TLS (1.0, 1.1, 1.2, 1.3).

- **Ejemplo recomendado:**

```
sslscan --no-failed uba.ar:443
```

Resumen de Ejecución Rápida en tu Kali VM

Cuando abras tu terminal en Kali para iniciar una práctica de auditoría, este sería tu "machete" o chuleta de comandos rápidos ejecutados en orden:

```
# 1. ¿A qué IP apunta el dominio de mi práctica?  
nslookup practica.local
```

```
# 2. ¿Qué otros equipos hay encendidos en mi segmento de
```

```
sudo netdiscover -r 192.168.1.0/24
```

```
# 3. ¿Tengo conectividad directa y cuántos saltos hay has  
ping -c 4 192.168.1.150  
traceroute -I 192.168.1.150
```

```
# 4. ¿La web tiene algún Firewall protegiéndola que pueda  
wafw00f http://192.168.1.150
```

```
# 5. ¿El canal seguro HTTPS (puerto 443) tiene cifrados o  
sslscan --no-failed 192.168.1.150:443
```

Con este flujo de trabajo no solo sabrás ejecutar los comandos, sino que entenderás perfectamente por qué estás ejecutando cada uno y qué valor aporta el resultado al siguiente paso de tu auditoría